

CISM CERTIFICATION EXAM SIMULATOR

Practice Exam 19

Domain III - Information Security Program

50 Questions	80 Minutes	Single Best Answer Format
-----------------	---------------	------------------------------

This publication contains original practice material designed for exam preparation. It does not reproduce confidential certification questions and is not affiliated with or endorsed by ISACA.

Instructions

- Allow approximately 80 minutes for this domain set.
- Select one best answer for every question.
- Record your selections before consulting the answer key.
- Review every explanation, including questions you answered correctly.

Questions

Question 1 (CISM5-058)

Scenario: A home-care provider is replacing in-person scheduling with a mobile service used by clinicians, patients, and family members. Its current security program focuses on corporate offices.

What should PRIMARILY drive the revised security program objectives?

- A. The products already licensed by the technology department
- B. The mobile service's business outcomes, sensitive information, obligations, dependencies, and risks
- C. The controls used by the provider's largest competitor
- D. The initiatives that require no change to clinical workflows

Question 2 (CISM5-059)

Scenario: A national sports federation shares services with independently governed regional associations. Security initiatives fail because no one knows which requirements are mandatory or who can escalate noncompliance.

Which mandate-setting action should the information security manager take FIRST?

- A. Publish technical procedures without addressing decision rights.
- B. Ask the federation's auditors to operate the security program.
- C. Let every regional association set unrelated program objectives.
- D. Obtain approval for a charter defining mandate, scope, shared responsibilities, sponsorship, and escalation.

Question 3 (CISM5-060)

Scenario: A laboratory network advances the opening of three collection sites by eight months. Identity integration, asset onboarding, and supplier assurance are scheduled after the new opening date.

Which roadmap adjustment is MOST appropriate for the accelerated openings?

- A. Reassess risk and dependencies, then propose a funded sequence aligned with the accelerated openings.
- B. Add every new task without changing priorities or funding.
- C. Keep the approved sequence because roadmap dates should remain fixed.
- D. Open the sites first and add security capabilities after operations stabilize.

Question 4 (CISM5-061)

Scenario: An education marketplace connects schools, tutors, payment services, and identity providers. The marketplace owns the customer relationship but not every supporting system.

Which scoping approach should the information security manager use?

- A. Assign all platform risk to external service providers.
- B. Limit scope to infrastructure directly owned by the marketplace.
- C. Map the end-to-end service, data flows, obligations, risks, dependencies, and accountable interfaces across participants.
- D. Include only participants that have reported a security incident.

Question 5 (CISM5-062)

Which input is MOST important when estimating resources for an enterprise access-review capability?

- A. The current number of employees in the security department
- B. The expected review population, risk tiers, frequency, workflow complexity, skills, service levels, and automation
- C. The office space assigned to the review team
- D. The average headcount of unrelated peer organizations

Question 6 (CISM5-063)

Scenario: A small investment firm needs advanced analysis of security program metrics but cannot justify a full-time specialist. Internal managers understand risk, business context, and decision authority.

Which analytics sourcing approach is MOST appropriate?

- A. Allow the external analyst to approve all risk decisions.
- B. Stop measuring program performance until an internal specialist is hired.
- C. Transfer ownership of metric definitions to the analytics provider.
- D. Use qualified external analysis under defined requirements while retaining internal definitions, interpretation, decisions, and knowledge transfer.

Question 7 (CISM5-064)

Scenario: A transportation firm proposes a shared security-data capability to replace disconnected reporting tools. Source quality is inconsistent, and several business units must change ownership processes.

Which business case would BEST support the funding decision?

- A. One based only on the number of product features
- B. One linking expected risk and decision improvements to data dependencies, operating changes, delivery feasibility, and total cost
- C. One promising that the capability will eliminate all reporting errors
- D. One based on the technology team's preferred supplier

Question 8 (CISM5-065)

Scenario: A food processor is connecting factory systems to enterprise services. Its security team understands corporate technology but lacks operational safety and industrial control governance experience.

Which competency action should the information security manager take FIRST?

- A. Assign all factory risk decisions to equipment vendors.
- B. Give every employee the same introductory security course.
- C. Create a competency plan combining targeted development, recruitment, cross-functional knowledge, and selective external support.
- D. Ask internal audit to operate factory security controls.

Question 9 (CISM5-066)

Who should normally approve retention and disposal requirements for a business dataset?

- A. The storage administrator
- B. The backup operator
- C. The accountable information owner
- D. The independent auditor

Question 10 (CISM5-067)

Which practice BEST maintains a useful inventory of information held in cloud services?

- A. Embedding discovery, ownership validation, classification, and lifecycle updates into acquisition, change, and termination processes
- B. Restricting it to services purchased by the technology department
- C. Assigning the security team as owner of every dataset
- D. Updating it only before external audits

Question 11 (CISM5-068)

Scenario: An architectural consultancy labels bid materials as restricted, but employees print them at shared locations and discard drafts without consistent protection.

Which action would BEST address the handling gap?

- A. Define and embed classification-based printing, collection, storage, transport, and disposal requirements in the workflow.
- B. Remove the restricted label from printed documents.
- C. Require the security manager to approve every print job.
- D. Measure only the total number of pages printed.

Question 12 (CISM5-069)

Scenario: A museum digitizes donor and collection records for long-term preservation. Some records must be retained, but owners, access needs, integrity checks, and disposition rules are undocumented.

Which lifecycle action should occur FIRST?

- A. Keep every digital copy indefinitely with unchanged access.
- B. Let storage administrators decide which records have lasting value.
- C. Assign accountable ownership and define classification, access, integrity, retention, review, and disposition requirements.
- D. Delete duplicate records before confirming preservation obligations.

Question 13 (CISM5-070)**What is the PRIMARY value of a security framework in program development?**

- A. It provides a structured basis for organizing, assessing, and improving relevant capabilities.
- B. It accepts residual risk for the organization.
- C. It guarantees compliance with all legal requirements.
- D. It mandates identical controls for every enterprise.

Question 14 (CISM5-071)**Which approach BEST supports responsible framework tailoring?**

- A. Implement every practice with equal priority regardless of relevance.
- B. Remove practices that require business participation.
- C. Map framework outcomes to business objectives, risks, obligations, and current capabilities, documenting justified priorities.
- D. Select only practices supported by existing tools.

Question 15 (CISM5-072)

Scenario: A software service maintains separate controls for a certification program and major customer contracts. Similar requirements are tested repeatedly under different names.

Which integration step is MOST appropriate?

- A. Discard customer-specific requirements after certification.
- B. Use the shortest requirement set as the enterprise baseline without gap analysis.
- C. Create separate implementations for every requirement statement.
- D. Map requirements to a governed common control and evidence model while preserving unique traceability.

Question 16 (CISM5-073)

Which document normally provides step-by-step instructions for performing a security task?

- A. Procedure
- B. Policy
- C. Guideline
- D. Program charter

Question 17 (CISM5-074)

Where should mandatory minimum requirements for administrative account logging normally be documented?

- A. In a recommended guideline
- B. In an approved security standard
- C. In an individual administrator's notes
- D. In an audit workpaper

Question 18 (CISM5-075)

Scenario: A payroll platform cannot meet a new encryption standard until its scheduled migration in five months. The business proposes restricted access and enhanced monitoring during the interim.

What should be required before the exception is approved?

- A. Permanent removal of payroll systems from the standard
- B. Documented risk, accountable approval, compensating controls, monitoring, review conditions, and an expiration date
- C. Informal approval by the migration project manager
- D. A statement that no previous incident involved the platform

Question 19 (CISM5-076)

Scenario: A call-center procedure tells agents to record identity evidence in case notes, while the approved data-handling standard prohibits storing that evidence in the case system.

Which document-governance action should the information security manager take FIRST?

- A. Let agents choose whichever document is easier to follow.
- B. Assume the procedure overrides the standard because it is more detailed.
- C. Engage the accountable owners to resolve the requirement, then approve and communicate aligned documents and instructions.
- D. Suspend all call-center operations until every security document is rewritten.

Question 20 (CISM5-077)

Scenario: A wholesale distributor is exposing reusable business services through APIs. Individual projects use inconsistent identity, authorization, data-protection, and monitoring approaches.

Which architecture-governance action should occur FIRST?

- A. Require every project to buy the same security product.
- B. Delay architecture decisions until all APIs are in production.
- C. Let each delivery team define independent security principles.
- D. Define security principles and shared capability requirements aligned with the API-based enterprise architecture and risk profile.

Question 21 (CISM5-078)

Scenario: A publishing group approves a target architecture using centralized rights management. Several legacy production systems cannot integrate until they are replaced over three years.

What should the architecture roadmap include?

- A. A gap analysis with dependencies, interim controls, priorities, and milestones
- B. Permanent exceptions for every legacy system
- C. Only the final target-state diagram
- D. Immediate migration regardless of production impact

Question 22 (CISM5-079)

Scenario: An emergency dispatch service has an approved outage tolerance, but proposed architecture designs do not show how dependencies and recovery capabilities satisfy it.

Which traceability artifact should the information security manager request?

- A. Traceability from the business tolerance and risk requirements to architecture decisions, dependencies, controls, and acceptance evidence
- B. A count of all devices included in each design
- C. Selection of the design with the most components
- D. Transfer of resilience accountability to the architecture vendor

Question 23 (CISM5-080)

Scenario: A rapidly growing design firm sends every technology change through the same architecture board. The backlog causes teams to bypass reviews, including some changes involving sensitive client data.

Which governance improvement is MOST appropriate?

- A. Remove architecture review from all internal changes.
- B. Make internal audit responsible for solution design.
- C. Approve changes according to purchase price alone.
- D. Introduce risk-tiered reviews, reusable approved patterns, early checkpoints, and a documented exception path.

Question 24 (CISM5-081)

Scenario: A port operator can replace fragmented identity services in a single shutdown or migrate terminal by terminal. A single change reaches consistency sooner, while staging requires temporary federation and duplicate support.

Which recommendation should guide the architecture decision?

- A. Choose the single shutdown because shorter schedules always reduce risk.
- B. Compare risk reduction, operational resilience, dependencies, interim controls, support capacity, lifecycle cost, and measurable exit criteria.
- C. Retain fragmented identity indefinitely to avoid transition risk.
- D. Allow each terminal to select an unrelated permanent architecture.

Question 25 (CISM5-082)

Which metric BEST measures the outcome of an information asset governance initiative?

- A. Number of meetings held by the asset team
- B. Percentage of high-value information assets with validated owners, current classifications, and compliant lifecycle controls
- C. Hours spent configuring the inventory tool
- D. Number of fields available in the inventory form

Question 26 (CISM5-083)

Scenario: An enterprise reports that 92 percent of security findings close on time. The measure combines low-impact documentation issues with critical control failures and does not show overdue age or ownership.

Which reporting change would MOST improve management action?

- A. Add more decorative charts without changing the data.
- B. Report only the enterprise average to preserve simplicity.
- C. Segment findings by risk, business service, age, root cause, accountable owner, and remediation status.
- D. Exclude overdue findings until their owners agree with the rating.

Question 27 (CISM5-084)

Scenario: A retailer's lowest maturity score concerns a low-impact internal process. A moderately mature supplier capability has recurring weaknesses affecting its largest sales channel.

Which maturity investment decision is BEST?

- A. Fund only the capability with the lowest score.
- B. Prioritize target maturity according to risk, business dependence, outcome gaps, dependencies, and expected value.
- C. Raise every capability by the same amount regardless of impact.
- D. Discard maturity information because capabilities differ.

Question 28 (CISM5-085)

Which characteristic is MOST important in an appropriately designed security control?

- A. It is the most restrictive control available.
- B. It uses the newest technology.
- C. It is identical to a competitor's implementation.
- D. It addresses a defined objective and risk within business, architecture, and requirement constraints.

Question 29 (CISM5-086)

Scenario: A disaster-relief organization proposes an access control requiring continuous connectivity. Field teams may lose communications while supporting urgent medical distribution.

Which field-access control approach should the security manager recommend?

- A. Deploy the control unchanged because maximum restriction always reduces total risk.
- B. Evaluate the risk and mission needs, then design resilient offline access, safeguards, accountability, and later reconciliation.
- C. Remove access requirements from all field systems.
- D. Let each field worker disable controls without oversight.

Question 30 (CISM5-087)

Scenario: A company plans to block unapproved data transfers based on information labels. Many repositories have no owners, and labels are incomplete or outdated.

Which control-design dependency should concern the information security manager MOST?

- A. The control does not use the most expensive technology.
- B. Unreliable classification and ownership may cause incomplete or inappropriate enforcement.
- C. The control includes both preventive and detective elements.
- D. The implementation team prefers a different dashboard layout.

Question 31 (CISM5-088)

Scenario: A subscription service can use a strict single verification method or layered methods selected by transaction risk. Both meet minimum requirements, but customers have varied accessibility and device constraints.

Which analysis should guide the final design?

- A. Compare threat coverage, fraud reduction, accessibility, failure modes, recovery, maintainability, and lifecycle cost.
- B. Choose the method requiring the most user steps.
- C. Select the design promoted most heavily by a supplier.
- D. Use the first method that meets a minimum checklist.

Question 32 (CISM5-089)

Scenario: A software company deploys a service for protecting application secrets. The technology is available, but teams have no migration schedule, exception path, support process, or accountable service owner.

What is required before the control is considered implemented?

- A. A vendor statement that the service was installed
- B. Transfer of control ownership to internal audit
- C. Consumption of the project's remaining budget
- D. Defined ownership, integration and migration plans, procedures, support, training, exceptions, and acceptance evidence

Question 33 (CISM5-090)

Scenario: A government agency evaluates security only after selecting software suppliers. Contract negotiations then reveal unmet requirements and costly exceptions.

Which program change would MOST improve future procurements?

- A. Embed risk-tiered security requirements, due diligence, evaluation, contract terms, testing, and acceptance throughout procurement.
- B. Allow suppliers to define the agency's risk tolerance.
- C. Ask internal audit to select all software controls.
- D. Perform a larger review after contract signature.

Question 34 (CISM5-091)

Scenario: A research company introduces approval for sharing study data externally. Employees bypass it because ownership is unclear, routine requests wait days, and urgent collaborations have no defined path.

Which adoption response should the manager take FIRST?

- A. Correct workflow barriers and manage interim risk
- B. Report implementation as successful because the workflow exists.
- C. Send more policy reminders without changing the process.
- D. Remove approval requirements from all external sharing.

Question 35 (CISM5-092)

Scenario: A shipping company pilots a new remote-access control with office employees. Vessel crews use intermittent satellite links, and neither offline behavior nor onboard support has been tested.

Which rollout decision is BEST?

- A. Deploy to every vessel because the office pilot passed.
- B. Cancel the control because the first pilot was limited.
- C. Validate representative vessel workflows, connectivity, support, success criteria, and rollback, then expand in controlled phases.
- D. Allow each vessel to decide whether remote-access control is needed.

Question 36 (CISM5-093)

Scenario: A company checks that backups complete successfully but has not tested whether critical data can be restored within business requirements or whether restored access remains appropriate.

What should the next control test include?

- A. Only a count of successful backup jobs
- B. A review of the backup policy's approval date
- C. The operator's statement that restoration should work
- D. Representative restoration, integrity and access validation, timing against requirements, exceptions, and evidence of corrective action

Question 37 (CISM5-094)

Scenario: Quarterly testing repeatedly finds active accounts for temporary staff. Teams close each finding by deleting listed accounts, but hiring systems send incomplete end dates to access administrators.

Which remediation action should the manager take NEXT?

- A. Close findings as soon as the listed accounts are deleted.
- B. Increase the length of the access policy without changing the process.
- C. Require root-cause correction of the end-date process, assign accountable owners, and track sustained results by risk.
- D. Make the assurance team responsible for account administration.

Question 38 (CISM5-095)

Which arrangement BEST supports independent assurance?

- A. Periodic independent review replaces all management monitoring.
- B. The control operator selects successful samples and approves the conclusion.
- C. The control owner prevents reviewers from examining exception records.
- D. A competent party independent of control operation selects suitable evidence and reports results through an appropriate governance path.

Question 39 (CISM5-096)

Scenario: A manufacturing site passes a checklist requiring visitor badges. Observations show visitors frequently enter production areas unescorted, and badge exceptions are not reviewed.

Which effectiveness conclusion is MOST appropriate?

- A. Conformity evidence is insufficient; operating failures, exception governance, and resulting risk require remediation and reassessment.
- B. Residual risk is acceptable because badges are issued.
- C. Checklist completion proves the control is effective.
- D. Further evaluation should wait until a visitor causes a loss.

Question 40 (CISM5-097)

Which result BEST indicates that a security awareness initiative is effective?

- A. The security team sends more messages than last year.
- B. Every employee receives identical technical material.
- C. The annual course contains more slides.
- D. Targeted employee behavior improves and the associated risk indicator declines.

Question 41 (CISM5-098)

Scenario: Recruiters receive general privacy training but continue placing excessive candidate information in interview notes shared with hiring panels.

Which training improvement is MOST appropriate?

- A. Repeat the same general course for every employee.
- B. Measure effectiveness only through attendance.
- C. Provide role-based scenarios and workflow prompts on appropriate note content, then reinforce and measure behavior.
- D. Make the security team write all interview notes.

Question 42 (CISM5-099)

Scenario: A charity's staff increasingly report suspicious messages, but fundraising teams still approve fraudulent contact-detail changes during campaign deadlines.

Which awareness response should the information security manager take NEXT?

- A. Declare success based only on increased message reporting.
- B. Stop measuring behavior because indicators conflict.
- C. Investigate deadline workflows and decision drivers, apply targeted reinforcement, and measure verification behavior over time.
- D. Send identical additional content to every employee without analysis.

Question 43 (CISM5-100)

Scenario: A retailer wants a provider to analyze detailed customer behavior. Procurement has reviewed price and functionality but not data use, security evidence, incidents, subcontractors, or deletion.

Which requirement set should the security manager recommend?

- A. Risk-based due diligence and defined data-use, security, evidence, incident, subcontractor, monitoring, retention, and exit terms
- B. Transfer of customer-data ownership to the provider
- C. Approval based solely on the provider's market reputation
- D. A general confidentiality statement as the only safeguard

Question 44 (CISM5-101)

Scenario: A payroll provider changes its identity-verification subcontractor without required notice. Employee data will be processed in a new location, and existing assurance evidence does not cover the service.

Which fourth-party action should occur FIRST?

- A. Assess the change against data, security, location, contractual, and business requirements and invoke approval or remediation rights.
- B. Assume operational control of the subcontractor's systems.
- C. Ignore the change because the direct provider remains accountable.
- D. Wait until the annual supplier review.

Question 45 (CISM5-102)

Scenario: A consulting firm ends a collaboration service. Primary documents are exported, but version history is missing, provider accounts remain active, and backup deletion is not evidenced.

Which exit decision is BEST?

- A. Close the exit because primary documents were returned.
- B. Keep provider access active for convenience.
- C. Accept a verbal statement that remaining copies are protected.
- D. Complete transfer, revocation, deletion evidence, and accountable acceptance

Question 46 (CISM5-103)

Scenario: Senior leaders receive a security report listing project tasks, alert totals, and policy counts. They cannot determine which program outcomes are off track or what decisions are required.

Which executive-reporting design would BEST support decisions?

- A. Add every underlying event record.
- B. Present trends against agreed outcomes and thresholds, explain business impact, and identify owners, actions, and decisions.
- C. Remove unfavorable trends until remediation is complete.
- D. Report only activity performed directly by security staff.

Question 47 (CISM5-104)

Scenario: Two mandatory program initiatives need the same specialists during the same quarter. Both deadlines are fixed, the resulting delivery risk exceeds tolerance, and the security manager cannot authorize additional funding.

Which capacity escalation is MOST appropriate?

- A. Commit to both deadlines without disclosing the constraint.
- B. Move one deadline so the dashboard remains green.
- C. Let the specialists choose which obligation to meet.
- D. Escalate impact, evidence, alternatives, and the required decision

Question 48 (CISM5-105)

Scenario: Business leaders reject a new security dashboard because its metrics do not reflect service priorities and accountability is unclear. Security designed it without stakeholder input.

Which engagement approach would BEST improve the dashboard?

- A. Require leaders to use the existing dashboard unchanged.
- B. Remove all risk measures and report only security activities.
- C. Jointly define desired outcomes, business context, thresholds, data ownership, actions, and decision responsibilities.
- D. Let each leader use unrelated definitions for the same metric.

Question 49 (CISM5-106)

Scenario: A lender automates document review that was previously performed by employees. Existing controls, training, quality checks, and metrics assume manual decisions.

Which program-maintenance action should occur FIRST?

- A. Keep every manual control unchanged because the business objective is stable.
- B. Assess changed workflows, information, decision ownership, failure modes, dependencies, and evidence, then update controls and measures.
- C. Exclude automated review from the security program.
- D. Wait for a confirmed failure before revising the program.

Question 50 (CISM5-107)

Scenario: A property operator wants digital twins of critical buildings to combine sensor, maintenance, occupancy, and supplier data. Data ownership, architecture dependencies, provider access, and existing control coverage are unclear.

Which emerging-technology governance approach is MOST appropriate?

- A. Permit unrestricted deployment until a loss occurs.
- B. Set guardrails, run a bounded pilot, monitor outcomes, and update controls
- C. Ban the technology permanently because current standards do not name it.
- D. Let each building create unrelated security requirements.

Answer Key

Domain III - Information Security Program

1 B	2 D	3 A	4 C	5 B
6 D	7 B	8 C	9 C	10 A
11 A	12 C	13 A	14 C	15 D
16 A	17 B	18 B	19 C	20 D
21 A	22 A	23 D	24 B	25 B
26 C	27 B	28 D	29 B	30 B
31 A	32 D	33 A	34 A	35 C
36 D	37 C	38 D	39 A	40 D
41 C	42 C	43 A	44 A	45 D
46 B	47 D	48 C	49 B	50 B

Detailed Explanations

Question 1 (CISM5-058)

Correct answer: B - The mobile service's business outcomes, sensitive information, obligations, dependencies, and risks

Program objectives should reflect the transformed service, its information, obligations, dependencies, and risk exposure. Existing products and competitor practices are only inputs, while avoiding workflow change may leave important clinical risks untreated.

Question 2 (CISM5-059)

Correct answer: D - Obtain approval for a charter defining mandate, scope, shared responsibilities, sponsorship, and escalation.

A sponsored charter establishes the authority and shared-accountability model needed across independent associations. Procedures cannot create authority, auditors should remain independent, and unrelated regional objectives would fragment the program.

Question 3 (CISM5-060)

Correct answer: A - Reassess risk and dependencies, then propose a funded sequence aligned with the accelerated openings.

The changed business milestone requires a risk- and dependency-based roadmap revision with realistic capacity and funding. Freezing the plan, adding unsupported work, or postponing security would leave the openings inadequately governed.

Question 4 (CISM5-061)

Correct answer: C - Map the end-to-end service, data flows, obligations, risks, dependencies, and accountable interfaces across participants.

Scope should follow the end-to-end business service and information risk, with responsibilities defined at each interface. Asset ownership and incident history do not remove exposure, and organizational accountability cannot be fully transferred to providers.

Question 5 (CISM5-062)

Correct answer: B - The expected review population, risk tiers, frequency, workflow complexity, skills, service levels, and automation

Capacity should be based on expected demand, risk, process complexity, service expectations, competence, and automation. Current staffing, office space, and peer averages do not establish the resources required for this capability.

Question 6 (CISM5-063)

Correct answer: D - Use qualified external analysis under defined requirements while retaining internal definitions, interpretation, decisions, and knowledge transfer.

External expertise can provide economical capability while the organization retains ownership of definitions, context, and decisions and develops internal knowledge. Outsourcing does not transfer risk authority or justify suspending measurement.

Question 7 (CISM5-064)

Correct answer: B - One linking expected risk and decision improvements to data dependencies, operating changes, delivery feasibility, and total cost

A sound business case connects expected program value and risk improvement to data prerequisites, process change, feasibility, and lifecycle cost. Feature counts and supplier preference lack business context, while eliminating every error is not credible.

Question 8 (CISM5-065)

Correct answer: C - Create a competency plan combining targeted development, recruitment, cross-functional knowledge, and selective external support.

A targeted competency plan addresses the distinct governance, safety, and technology knowledge required through several workforce options. Vendors do not own enterprise risk, generic training is insufficient, and audit should not operate controls.

Question 9 (CISM5-066)

Correct answer: C - The accountable information owner

The information owner is accountable for lifecycle requirements, informed by applicable legal and business needs. Administrators and operators implement those requirements, while auditors assess rather than approve them.

Question 10 (CISM5-067)

Correct answer: A - Embedding discovery, ownership validation, classification, and lifecycle updates into acquisition, change, and termination processes

Inventory maintenance must accompany the events that create, change, and retire cloud information assets. Audit-only or technology-purchase views become incomplete, and security does not own all business information.

Question 11 (CISM5-068)

Correct answer: A - Define and embed classification-based printing, collection, storage, transport, and disposal requirements in the workflow.

Clear lifecycle handling rules embedded in the printing workflow make classification actionable. Removing labels hides risk, central approval is unlikely to scale, and page counts do not demonstrate appropriate protection.

Question 12 (CISM5-069)

Correct answer: C - Assign accountable ownership and define classification, access, integrity, retention, review, and disposition requirements.

Ownership and explicit lifecycle requirements are prerequisites for defensible preservation and disposal. Indefinite storage and administrator-only decisions lack business authority, while premature deletion could conflict with preservation needs.

Question 13 (CISM5-070)

Correct answer: A - It provides a structured basis for organizing, assessing, and improving relevant capabilities.

A framework offers a structured reference for organizing and improving capabilities when adapted to context. It does not accept risk, guarantee universal compliance, or prescribe identical controls for all organizations.

Question 14 (CISM5-071)

Correct answer: C - Map framework outcomes to business objectives, risks, obligations, and current capabilities, documenting justified priorities.

Responsible tailoring uses organizational context and preserves a documented rationale for priorities. Equal treatment ignores risk, while convenience-based omission can leave material business and compliance needs unaddressed.

Question 15 (CISM5-072)

Correct answer: D - Map requirements to a governed common control and evidence model while preserving unique traceability.

A common control and evidence model reduces duplication while retaining traceability to distinct obligations. Certification does not replace contracts, separate implementations waste effort, and selecting the shortest set can omit important needs.

Question 16 (CISM5-073)

Correct answer: A - Procedure

A procedure defines how a task is performed. Policy states management direction, a guideline offers recommendations, and a charter establishes program mandate and scope.

Question 17 (CISM5-074)

Correct answer: B - In an approved security standard

A standard contains specific mandatory requirements supporting policy direction. Guidelines are advisory, personal notes lack authority, and audit workpapers assess rather than establish operational requirements.

Question 18 (CISM5-075)

Correct answer: B - Documented risk, accountable approval, compensating controls, monitoring, review conditions, and an expiration date

A governed exception is risk-based, approved by proper authority, protected, monitored, reviewed, and time-limited. Permanent exclusion and informal approval bypass governance, while incident history alone does not demonstrate acceptable future risk.

Question 19 (CISM5-076)

Correct answer: C - Engage the accountable owners to resolve the requirement, then approve and communicate aligned documents and instructions.

Conflicting requirements need an authorized, risk-based resolution and consistent communication to operations. Local choice and automatic procedure precedence are invalid, while suspending the entire service is disproportionate before resolving the specific conflict.

Question 20 (CISM5-077)

Correct answer: D - Define security principles and shared capability requirements aligned with the API-based enterprise architecture and risk profile.

Aligned principles and shared capabilities provide coherent direction for reusable services before project choices become fixed. Product uniformity does not ensure architecture alignment, independent principles fragment the environment, and late definition creates avoidable redesign.

Question 21 (CISM5-078)

Correct answer: A - A gap analysis with dependencies, interim controls, priorities, and milestones

A useful roadmap defines how to move from current constraints to the target while managing transitional risk and accountability. A target diagram alone is incomplete, permanent exceptions defeat convergence, and immediate migration may create unacceptable business disruption.

Question 22 (CISM5-079)

Correct answer: A - Traceability from the business tolerance and risk requirements to architecture decisions, dependencies, controls, and acceptance evidence

Traceability demonstrates whether design choices and controls actually meet the approved business tolerance and provides a basis for acceptance. Component counts do not prove resilience, and the organization retains accountability rather than transferring it to a vendor.

Question 23 (CISM5-080)

Correct answer: D - Introduce risk-tiered reviews, reusable approved patterns, early checkpoints, and a documented exception path.

Risk tiers and reusable patterns make governance scalable while preserving oversight of material changes and accountable exceptions. Broad exclusion and price-only approval can miss significant risk, while audit should remain independent of design.

Question 24 (CISM5-081)

Correct answer: B - Compare risk reduction, operational resilience, dependencies, interim controls, support capacity, lifecycle cost, and measurable exit criteria.

The transition choice should balance target benefits with operational risk, dependencies, interim safeguards, support, and total cost. Speed alone is not decisive, indefinite delay preserves weaknesses, and unrelated targets perpetuate fragmentation.

Question 25 (CISM5-082)

Correct answer: B - Percentage of high-value information assets with validated owners, current classifications, and compliant lifecycle controls

Validated ownership, classification, and lifecycle controls show whether high-value assets are actually governed. Meetings, configuration effort, and form fields are activity or design measures rather than outcome evidence.

Question 26 (CISM5-083)

Correct answer: C - Segment findings by risk, business service, age, root cause, accountable owner, and remediation status.

Risk and ownership segmentation reveals material exposure and where decisions or intervention are needed. Decorative changes and averages obscure critical delays, while excluding disputed findings weakens transparency.

Question 27 (CISM5-084)

Correct answer: B - Prioritize target maturity according to risk, business dependence, outcome gaps, dependencies, and expected value.

Maturity targets should reflect risk, business reliance, outcome needs, dependencies, and value, which may favor supplier improvement. Score-only and uniform investment ignore impact, while maturity remains a useful input when combined with context.

Question 28 (CISM5-085)

Correct answer: D - It addresses a defined objective and risk within business, architecture, and requirement constraints.

Appropriate design is traceable to the intended objective and risk and fits applicable requirements and operating constraints. Restrictiveness, novelty, and competitor use do not demonstrate suitability or proportionality.

Question 29 (CISM5-086)

Correct answer: B - Evaluate the risk and mission needs, then design resilient offline access, safeguards, accountability, and later reconciliation.

The design should protect access while supporting predictable emergency conditions through governed offline operation and reconciliation. An inflexible control can create mission risk, while removing or individually disabling controls abandons consistent accountability.

Question 30 (CISM5-087)

Correct answer: B - Unreliable classification and ownership may cause incomplete or inappropriate enforcement.

The proposed control depends on accurate labels and accountable ownership; weak inputs can undermine both coverage and business decisions. Product cost, layered operation, and dashboard preferences do not address that fundamental dependency.

Question 31 (CISM5-088)

Correct answer: A - Compare threat coverage, fraud reduction, accessibility, failure modes, recovery, maintainability, and lifecycle cost.

The design decision should balance effective risk reduction with accessibility, resilience, recovery, maintainability, and cost. More steps, supplier promotion, and minimum conformity alone do not establish the best enterprise outcome.

Question 32 (CISM5-089)

Correct answer: D - Defined ownership, integration and migration plans, procedures, support, training, exceptions, and acceptance evidence

Implementation requires an operating model that integrates people, process, and technology and meets acceptance criteria. Installation and spending do not prove readiness, while internal audit should independently assess rather than own the service.

Question 33 (CISM5-090)

Correct answer: A - Embed risk-tiered security requirements, due diligence, evaluation, contract terms, testing, and acceptance throughout procurement.

Lifecycle integration lets security requirements and risk influence selection, contracting, and acceptance before commitments become costly. Post-signature review is late, suppliers do not set risk tolerance, and audit should not own procurement control design.

Question 34 (CISM5-091)

Correct answer: A - Correct workflow barriers and manage interim risk

The program should correct the ownership and workflow barriers preventing effective operation while governing interim exposure. Availability and reminders do not fix the design, while removing approval abandons the control objective.

Question 35 (CISM5-092)

Correct answer: C - Validate representative vessel workflows, connectivity, support, success criteria, and rollback, then expand in controlled phases.

A phased rollout should extend evidence to the distinct vessel environment and confirm operational and recovery readiness. Office success cannot simply be generalized, cancellation discards a viable control, and local discretion undermines consistent governance.

Question 36 (CISM5-093)

Correct answer: D - Representative restoration, integrity and access validation, timing against requirements, exceptions, and evidence of corrective action

The control objective includes usable, timely, and properly protected restoration, so testing must go beyond backup completion. Policy dates, job counts, and operator assertions do not demonstrate recovery effectiveness.

Question 37 (CISM5-094)

Correct answer: C - Require root-cause correction of the end-date process, assign accountable owners, and track sustained results by risk.

The recurring failure is caused by incomplete source data, so sustainable remediation must address that process and be tracked to results. Account-by-account cleanup and policy length do not fix the cause, and assurance should not operate the control.

Question 38 (CISM5-095)

Correct answer: D - A competent party independent of control operation selects suitable evidence and reports results through an appropriate governance path.

Independence from operation, objective evidence selection, and appropriate reporting support credible assurance. Operator self-approval and evidence restrictions create bias, while independent review complements rather than replaces ongoing management monitoring.

Question 39 (CISM5-096)

Correct answer: A - Conformity evidence is insufficient; operating failures, exception governance, and resulting risk require remediation and reassessment.

Documented conformity does not override evidence that the control fails in practice or determine risk acceptance. Badge issuance alone is insufficient, and waiting for a loss would replace proactive assurance with incident-driven action.

Question 40 (CISM5-097)

Correct answer: D - Targeted employee behavior improves and the associated risk indicator declines.

Effective awareness changes relevant decisions or behavior and reduces the targeted exposure. Message volume, identical content, and course length are activity measures that do not demonstrate risk-reducing outcomes.

Question 41 (CISM5-098)

Correct answer: C - Provide role-based scenarios and workflow prompts on appropriate note content, then reinforce and measure behavior.

Role-specific scenarios and in-workflow guidance address the actual decision and enable behavioral measurement. Generic repetition and attendance are indirect, while transferring business work to security is neither scalable nor properly owned.

Question 42 (CISM5-099)

Correct answer: C - Investigate deadline workflows and decision drivers, apply targeted reinforcement, and measure verification behavior over time.

The segmented evidence identifies a specific risky behavior and operating context that require targeted analysis, intervention, and follow-up measurement. Reporting volume alone does not negate the gap, while ending measurement or using generic content will not address its cause.

Question 43 (CISM5-100)

Correct answer: A - Risk-based due diligence and defined data-use, security, evidence, incident, subcontractor, monitoring, retention, and exit terms

The service requires lifecycle governance proportionate to customer-data risk, including use, assurance, dependencies, incidents, retention, monitoring, and exit. A clause or reputation is insufficient, and information ownership remains with the accountable organization.

Question 44 (CISM5-101)

Correct answer: A - Assess the change against data, security, location, contractual, and business requirements and invoke approval or remediation rights.

The unapproved material change requires timely assessment and use of contractual governance before continued processing is accepted. Direct-provider accountability does not remove fourth-party risk, the customer should not operate the subcontractor, and annual review is too late.

Question 45 (CISM5-102)

Correct answer: D - Complete transfer, revocation, deletion evidence, and accountable acceptance

Exit remains incomplete while required information, active access, and unverified copies persist. Primary documents alone are insufficient, continued access preserves exposure, and verbal assurance is weak evidence of deletion.

Question 46 (CISM5-103)

Correct answer: B - Present trends against agreed outcomes and thresholds, explain business impact, and identify owners, actions, and decisions.

Management reporting should connect performance to outcomes, risk significance, accountability, and decisions. Raw detail obscures priorities, withholding results undermines oversight, and security-only activity can hide enterprise dependencies.

Question 47 (CISM5-104)

Correct answer: D - Escalate impact, evidence, alternatives, and the required decision

A material conflict beyond the manager's authority requires transparent escalation with decision-ready options. Hidden commitments, cosmetic date changes, and informal staff prioritization bypass accountable governance.

Question 48 (CISM5-105)

Correct answer: C - Jointly define desired outcomes, business context, thresholds, data ownership, actions, and decision responsibilities.

Joint design creates relevant, consistently defined measures with clear accountability and decision use. Unilateral enforcement weakens adoption, activity-only reporting misses outcomes, and unrelated definitions prevent meaningful comparison.

Question 49 (CISM5-106)

Correct answer: B - Assess changed workflows, information, decision ownership, failure modes, dependencies, and evidence, then update controls and measures.

Automation changes how decisions are made and evidenced, requiring timely reassessment of ownership, dependencies, controls, competence, and measures. Unchanged manual controls may not fit, exclusion abandons governance, and waiting is reactive.

Question 50 (CISM5-107)

Correct answer: B - Set guardrails, run a bounded pilot, monitor outcomes, and update controls

Governed experimentation supports business learning while addressing data, architecture, supplier, and operational risks and feeding evidence into program improvement. Unrestricted deployment lacks safeguards, a permanent ban avoids proportionate evaluation, and local rules fragment governance.